

Secure Coding Review — Python (Task 3)

Scope: Flask app (vulnerable_app/app.py).

Method: Manual review with OWASP/CERT guidance; conceptual static analysis.

Critical Findings:

F1 SQL Injection (/login): use parameterized queries; hash passwords.

F2 Command Injection (/exec): avoid shell=True; validate; shlex.split.

F3 Path Traversal (/read): sanitize filename; enforce base dir.

F4 Code Injection (/calc): remove eval; safe arithmetic parser.

F5 Unsafe Deserialization (/loads): do not use pickle on untrusted data.

Config Issues:

F6 Hardcoded secret → env var/secret manager.

F7 Debug=True → disable in prod.

F8 Add CSRF, secure cookies, HTTPS.

Recommendations: validate inputs, parameterize SQL, remove dangerous patterns, secrets in env vars, enable TLS, logging & tests, Bandit & pip-audit in CI.